

FibexSign

Informe de Correcciones de Seguridad

GrupoConex — Plataforma de firma electrónica self-hosted ("Firma")

Alcance: `apps/OpenSignServer` y `apps/OpenSign` — fallas del Lote 1 de caja blanca

Rama `fix/auth-security`, commits `6eeec553` y `95bcc45b`

Generado: 2026-10-01

Hecho por: Ciclo Fibex (GDA)

Este informe documenta las correcciones aplicadas a las fallas de seguridad y de manejo de errores registradas en el Informe de Pruebas de Caja Blanca del 2026-09-30, junto con los hallazgos adicionales de cuatro rondas de revisión de seguridad. Incluye la verificación realizada, los pasos de despliegue y lo que queda pendiente.

Índice

1. Resumen ejecutivo
2. Metodología de corrección
3. Fallas de seguridad corregidas (SEC)
4. Cadenas de ataque cerradas
5. Hallazgos de las revisiones de seguridad
6. Defectos de manejo de errores corregidos (DEF)
7. Componentes nuevos
8. Cambios en el frontend
9. Verificación y cobertura
10. Despliegue
11. Pendientes

1. Resumen ejecutivo

Las 12 fallas registradas como defectos conocidos en el Lote 1 (7 de seguridad y 5 de manejo de errores) están corregidas. Ninguna spec queda pendiente. Además se corrigieron los hallazgos de cuatro rondas de revisión de seguridad, entre ellos un permiso público crítico en `contracts_Users` que no formaba parte del informe original.

Indicador	Valor
Fallas SEC corregidas	7 / 7 (SEC-01 a SEC-07)
Defectos DEF corregidos	5 / 5 (DEF-01 a DEF-05)
Hallazgos adicionales corregidos	N1–N4, N6, P1–P5, R2–R5, R7
Specs del servidor	273 → 694 , 0 fallos
Specs pendientes (defectos conocidos)	14 → 0
Tests del frontend	184 en verde
Archivos del Lote 1 + componentes nuevos	100 % líneas / ramas / funciones
Hallazgos abiertos de gravedad alta	1 — H1, pre-registro de email (PR aparte)

Lo más importante

- **Toma de cuenta por email cerrada.** `adduser` ya no sobrescribe contraseñas (SEC-05) y el OTP ya no se puede adivinar ni reutilizar: 6 dígitos criptográficos, guardado como HMAC, un solo uso, bloqueo a los 5 intentos y máximo 3 envíos cada 15 minutos (SEC-01, SEC-02, SEC-03).
- **Permiso público crítico cerrado (P1).** Cualquier usuario autenticado podía crearse una fila `contracts_Admin` en un tenant ajeno. Ahora las filas solo se crean desde el servidor y un guard controla quién puede modificar cada campo.
- **Rate limit efectivo.** El límite de intentos ya no se puede evadir con `/batch`, variantes de ruta o cambiando el `Content-Type`.

Queda abierto H1 (ALTA): el registro público sin verificación de email permite reservar la cuenta de un firmante antes de que le envíen un documento. Se corregirá en un PR propio con sus pruebas de seguridad (sección 11).

2. Metodología de corrección

- **TDD con las specs del Lote 1 como RED.** Cada defecto estaba marcado con `knownDefect`, que deja la spec pendiente mientras el defecto existe y falla en cuanto se corrige. Al corregir, el marcador se reemplaza por una spec normal que queda como prueba de regresión.
- **Specs nuevas antes del código** para cada hallazgo adicional, verificando que fallaran contra el código anterior. Para P1 se aplicó en las specs el permiso real de producción con `setCLP`.
- **Cuatro rondas de revisión de seguridad** y revisión de calidad de código después de cada ronda. Cada ronda se volvió a probar completa antes de pasar a la siguiente.
- **Verificación independiente:** la suite completa se corrió de nuevo fuera de los agentes que implementaron los cambios, y la cobertura se midió con `c8`.
- Las decisiones de diseño (longitud del OTP, límite de reenvíos, tratamiento de cuentas vinculadas, rotación de contraseñas de invitados) fueron tomadas por el equipo antes de implementar.

Rondas

Ronda	Contenido	Specs servidor / frontend
1	SEC-01 a SEC-07, DEF-02	425 / 149
2	N1–N4, N6; DEF-01, DEF-04; scripts de migración y rotación	525 / 176
3	P1–P5: permisos de <code>contracts_Users</code> , <code>/batch</code> , rutas, proxy	615 / 176
4	R2–R5, R7: dueño de fila, OrgAdmin, DoS de <code>/batch</code> , email de <code>_User</code> , migraciones	691 / 184
Cierre	DEF-03, DEF-05 y rama 202 de contactos (commit <code>95bcc45b</code>)	694 / 184

3. Fallas de seguridad corregidas (SEC)

ID	Gravedad	Falla	Corrección
SEC-05	CRÍTICA	<code>addUser.js</code> : si el email ya existía, sobrescribía con master key la contraseña de esa cuenta, aunque fuera de otro tenant.	Nunca toca la contraseña de una cuenta existente. Si la cuenta pertenece a cualquier tenant responde error 137. Una cuenta sin tenant se vincula marcada con <code>IsLinkedAccount</code> y sin control de su contraseña.
SEC-03	ALTA (cadena)	<code>VerifyEmail.js</code> : sin expiración, sin bloqueo por intentos y sin rate limit; servía de oráculo para adivinar el OTP.	Usa la política compartida de OTP: expira a los 10 min y bloquea a los 5 intentos. <code>/functions/verifyemail</code> pasa al rate limit estricto.
SEC-06	MEDIA	<code>resetPassword.js</code> : un OrgAdmin podía resetear la contraseña de usuarios de otras organizaciones del tenant; un admin deshabilitado también podía hacerlo.	Excluye a quien llama si está deshabilitado, a las cuentas vinculadas y, para OrgAdmin, a usuarios fuera de su organización.
SEC-01	MEDIA	<code>AuthLoginAsMail.js</code> : el OTP se podía reutilizar durante sus 10 minutos de vigencia.	Consumo de un solo uso: solo la primera validación gana (contador atómico). El código guardado se invalida.
SEC-02	BAJA a MEDIA	<code>VerifyEmail.js</code> : no comparaba el email del OTP con el usuario de la sesión.	El email debe coincidir con <code>request.user</code> .
SEC-07	BAJA a MEDIA	<code>usersignup.js</code> : el rol se validaba después de crear la cuenta y dejaba un <code>_User</code> huérfano con sesión.	Valida los datos antes de crear la cuenta. El rol se limita a una lista permitida (<code>contracts_User</code>).
SEC-04	BAJA	<code>addUser.js</code> : la respuesta incluía el <code>_User</code> completo con la contraseña en texto plano.	La respuesta devuelve solo un puntero al usuario.

4. Cadenas de ataque cerradas

Cadena A — toma de cuenta con `adduser` (SEC-05)

Paso del ataque	Qué lo bloquea ahora
1. Un anónimo se registra como <code>contracts_Admin</code> de un tenant propio.	<code>usersignup</code> solo acepta el rol <code>contracts_User</code> (SEC-07). <code>addadmin</code> valida sus datos (N6).
2. Llama a <code>adduser</code> con el email de la víctima y una contraseña elegida.	La cuenta de la víctima pertenece a un tenant: se rechaza con error 137.
3. El error 202 hacía que se sobrescribiera la contraseña con master key.	Esa rama ya no existe: nunca se cambia la contraseña de una cuenta existente.
Variante: crearse directamente una fila <code>contracts_Admin</code> en un tenant ajeno y usar <code>resetpassword</code> (P1).	La CLP de creación de <code>contracts_Users</code> queda cerrada y un <code>guard beforeSave</code> rechaza la creación desde el cliente.

Cadena B — fuerza bruta del OTP (SEC-03 + SEC-01)

Paso del ataque	Qué lo bloquea ahora
1. Pedir un OTP para la víctima (reiniciaba los intentos fallidos).	Máximo 3 envíos cada 15 min por email. Reenviar no reinicia intentos ni desbloquea.
2. Probar los ~9.000 códigos de 4 dígitos con <code>verifyemail</code> .	6 dígitos (900.000 valores) generados con <code>crypto</code> ; bloqueo a los 5 intentos, contado de forma atómica incluso con peticiones en paralelo (N2).
3. Saltar el rate limit agrupando intentos en <code>/batch</code> .	Rate limit nativo de Parse por sub-petición, más un <code>guard</code> de <code>/batch</code> antes de parsear el cuerpo (N2b, P3, R4).
4. Usar el código acertado en <code>AuthLoginAsMail</code> para obtener la sesión.	El OTP se guarda como HMAC, es de un solo uso y expira a los 10 min.

5. Hallazgos de las revisiones de seguridad

Hallazgos que no estaban en el informe de caja blanca y que aparecieron en las revisiones posteriores. La gravedad se indica cuando el revisor la asignó.

ID	Gravedad	Hallazgo	Corrección
P1	CRÍTICA	CLP de <code>contracts_Users</code> con <code>create/update</code> públicos: cualquier usuario autenticado podía crearse una fila de Admin en otro tenant o borrar <code>IsLinkedAccount</code> .	Guard <code>beforeSave / beforeDelete</code> y migración que cierra la CLP de creación. Las escrituras del servidor usan master key.
N1	ALTA	Los firmantes invitados son <code>_User</code> sin tenant: <code>adduser</code> los vinculaba y luego <code>resetpassword</code> permitía tomar la cuenta.	Marca <code>IsLinkedAccount</code> ; <code>resetpassword</code> y <code>deleteuser</code> excluyen esas cuentas.
N2	ALTA	Bloqueo e intentos de reenvío con lectura-luego-escritura (carrera) y <code>/batch</code> fuera del rate limit.	Contadores atómicos "claim-first", fila única por email (índice <code>Email_unique</code>) y rate limit nativo de Parse.
N3	—	Comparación de rutas con <code>endsWith</code> sin normalizar.	Rutas normalizadas antes de comparar.
N4	—	Invitados creados con contraseña igual a su email.	Contraseña aleatoria para invitados nuevos y script <code>rotate-guest-passwords.js</code> para los existentes.
N6	—	<code>addadmin</code> no validaba sus datos.	Validación compartida <code>assertValidUserDetails</code> .
P2	—	<code>deleteuser</code> no respetaba <code>IsLinkedAccount</code> .	Ignora las cuentas vinculadas.
P3	—	La inspección de <code>/batch</code> se evadía con <code>Content-Type: text/plain</code> .	Se parsea con cualquier content-type.
P4	—	Variantes de ruta (<code>/.</code> , <code>..</code> , <code>%4D</code>) evadían el rate limit.	<code>normalizeRequestPath</code> para rutas y sub-rutas.
P5	—	Sin <code>TRUST_PROXY_HOPS</code> , detrás de un proxy todos los clientes comparten límite.	Advertencia al arrancar en producción, sin bloquear el arranque.
R2	—	Filas de <code>contracts_Users</code> sin <code>_wperm</code> editables por cualquiera, incluidos contadores de cuota.	Las modificaciones exigen sesión del dueño de la fila o de un Admin activo del mismo tenant; los campos de autorización y contadores son solo del servidor.
R3	—	Un OrgAdmin podía deshabilitar al Admin.	OrgAdmin solo puede cambiar <code>IsDisabled</code> de miembros no administradores.
R4	—	Parseo de hasta 100 MB en <code>/batch</code> sin autenticación (DoS).	Límite por IP antes de parsear, 10 MB y máximo 50 sub-peticiones.
R5	—	Un usuario podía cambiar su propio email o username sin verificación.	Guard <code>beforeSave</code> de <code>_User</code> rechaza esos cambios desde el cliente.
R7	—	Migraciones bloqueantes al arranque; comparación no constante de la master key.	Migraciones esperadas antes de <code>listen</code> , cada paso aislado; <code>timingSafeEqual</code> en <code>UpdateExistUserAsAdmin</code> .

R1 (organizaciones y equipos sin ACL) fue descartado con datos: esas clases ya tienen la CLP de update cerrada. N5 se elevó a H1 y queda pendiente (sección 11).

6. Defectos de manejo de errores corregidos (DEF)

ID	Archivo	Defecto	Corrección
DEF-01	AuthLoginAsMail.js	Llamaba a <code>reject()</code> no declarado; el error se convertía en "Result not found".	Error controlado en la rama de guardado vacío.
DEF-02	SendMailOTPv1.js	Resolvía los errores como valor (el cliente recibía <code>{}</code>) y respondía "Otp send" aunque fallara el envío.	Rechaza con <code>Parse.Error</code> controlado; nunca confirma un envío fallido.
DEF-03	getUserId.js	Sin coincidencia resolvía con un <code>TypeError</code> ; una falla de consulta se resolvía como valor.	Rechaza con <code>OBJECT_NOT_FOUND</code> ("User not found.") y propaga el error original. <code>savecontact</code> y <code>editcontact</code> ya no guardan punteros con <code>objectId</code> indefinido.
DEF-04	addUser.js	Filtraba un <code>TypeError</code> crudo si el username existía con otro email.	Error de dominio controlado.
DEF-05	UpdateExistUserAsAdmin.js	Filtraba un <code>TypeError</code> crudo si la fila no tenía tenant.	Valida <code>TenantId</code> y <code>UserId</code> antes de crear la organización o el equipo; responde 400 con "User has no tenant." o "User has no linked account." sin escribir nada.

7. Componentes nuevos

Archivo	Función
<code>cloud/parsefunction/shared/otpPolicy.js</code>	Política única de OTP: generación criptográfica de 6 dígitos, HMAC-SHA256 con comparación en tiempo constante, TTL de 10 min, un solo uso, 5 intentos y 3 envíos cada 15 min con contadores atómicos.
<code>cloud/parsefunction/contractsUsersGuard.js</code>	<code>beforeSave</code> / <code>beforeDelete</code> de <code>contracts_Users</code> : creación solo desde el servidor, campos de autorización y contadores solo del servidor, modificaciones por el dueño o un Admin activo del tenant, OrgAdmin limitado a <code>IsDisabled</code> .
<code>cloud/parsefunction/userAccountGuard.js</code>	<code>beforeSave</code> de <code>_User</code> : bloquea cambios de email y username desde el cliente.
<code>cloud/parsefunction/shared/createUserAccount.js</code>	Creación de cuentas compartida; contraseña aleatoria para invitados (<code>generateGuestPassword</code>).
<code>utils/authRateLimiter.js</code>	Rate limit de rutas de autenticación con rutas normalizadas y guard de <code>/batch</code> previo al parseo del cuerpo.
<code>databases/migrations/20260930120000-lock_contracts_users_create_clp.cjs</code>	Cierra la CLP de creación de <code>contracts_Users</code> (incluye <code>down</code>).
<code>scripts/migrate-otp-table.js</code>	Deja una fila por email en <code>defaultdata_Otp</code> , crea el índice único y borra OTP en texto plano. Corre al arrancar.
<code>scripts/rotate-guest-passwords.js</code>	Detecta invitados cuya contraseña es su email, la rota y revoca sus sesiones. Simulación por defecto; aplica con <code>--apply</code> .

8. Cambios en el frontend

- Campos de OTP de 6 dígitos en login, verificación de email y acceso de invitados (`src/utls/otpPolicy.js`).
- Mensajes nuevos para el límite de reenvíos y el email duplicado en los 7 idiomas (de, en, es, fr, hi, it, kr).
- El aviso de "OTP enviado" solo aparece si el envío tuvo éxito.
- Las modificaciones de `contracts_Users` envían el token de sesión (`X-Parse-Session-Token`). Dos llamadas usaban un header mal nombrado; un test vigila que todas lo envíen.
- Manejo de errores de `usersignup` en `Login.jsx` y mensaje para el error 137 en `AddUser.jsx`.

El frontend y el servidor deben desplegarse juntos: el frontend anterior no envía el token de sesión en esas modificaciones y fallarían contra el servidor nuevo.

9. Verificación y cobertura

Suite	Resultado
Servidor (Jasmine)	694 specs, 0 fallos, 0 pendientes
Frontend	184 tests en verde

Cobertura por archivo (sentencias / ramas / funciones / líneas)

Medida con `c8` el 2026-10-01 sobre el commit `95bcc45b`.

Archivo	Cobertura
Los 14 archivos del Lote 1 (<code>loginUser</code> , <code>AuthLoginAsMail</code> , <code>usersignup</code> , <code>AddAdmin</code> , <code>addUser</code> , <code>UpdateExistUserAsAdmin</code> , <code>CheckAdminExist</code> , <code>createUserAccount</code> , <code>resetPassword</code> , <code>VerifyEmail</code> , <code>SendMailOTPv1</code> , <code>getUserDetails</code> , <code>isextenduser</code> , <code>getId</code>)	100 / 100 / 100 / 100
<code>otpPolicy.js</code> , <code>contractsUsersGuard.js</code> , <code>userAccountGuard.js</code>	100 / 100 / 100 / 100
<code>utils/authRateLimiter.js</code>	98,1 / 92,9 / 100 / 98,1
<code>customRoute/deleteAccount/deleteUser.js</code>	43,8 / 57,5 / 60 / 43,8 (se completa en el Lote 2)

Specs nuevas destacadas

- `shared/otpPolicy.spec.js` , `contractsUsersGuard.spec.js` , `userAccountGuard.spec.js`
- `rate-limit-batch.spec.js` , `server-hardening.spec.js` , `contractsUsersClpMigration.spec.js`
- `guestPasswords.spec.js` , `rotate-guest-passwords.spec.js` , `migrate-otp-table.spec.js`
- `deleteUser.linked.spec.js` , `runDbMigrations.spec.js` , `contactUserLookup.spec.js`

10. Despliegue

1. Desplegar **frontend y servidor juntos**.
2. Configurar `TRUST_PROXY_HOPS` en producción con el número de proxies delante del servidor. Sin esta variable, todos los clientes detrás del proxy comparten el mismo límite.
3. Ejecutar `scripts/rotate-guest-passwords.js` en modo simulación, revisar el resultado y luego con `--apply`.
4. Las migraciones (CLP de `contracts_Users` y tabla de OTP) corren al arrancar el servidor.
5. Opcional: `BATCH_RATE_LIMIT_MAX` para ajustar el límite de `/batch`.

Efectos esperados al desplegar

- Los OTP de 4 dígitos emitidos antes del despliegue dejan de ser válidos.
- El rate limit vive en memoria de cada proceso; con varias instancias conviene configurar Redis.
- Las cuentas vinculadas antes de esta corrección no tienen `IsLinkedAccount`; hasta rellenar esa marca no reciben las nuevas protecciones de `resetpassword` y `deleteuser`.

11. Pendientes

Prioridad	Pendiente	Plan
ALTA	H1 — pre-registro de email. <code>POST /users</code> es público y no verifica el email: un atacante reserva la cuenta de un firmante y, cuando le envían un documento, lo puede leer.	PR propio con pruebas de seguridad: CLP de creación de <code>_User</code> cerrada y creación solo con master key; en el primer OTP válido de una cuenta no verificada, contraseña nueva y sesiones borradas.
MEDIA	Rellenar <code>IsLinkedAccount</code> y ACL en filas existentes.	Script de backfill como paso de despliegue.
MEDIA	<code>editContact</code> marca como borrado el contacto anterior antes de crear la cuenta y no lo revierte si falla.	Ticket aparte: hacer la operación atómica.
MEDIA	En <code>savecontact</code> y <code>editContact</code> , los errores distintos de 202 se pierden y la función devuelve vacío.	Ticket aparte.
—	R6: vinculación de cuentas huérfanas sin confirmación del dueño.	Flujo de invitación con confirmación.
—	Impedir deshabilitar al último Admin del tenant.	Ticket aparte.
—	Los límites de <code>/batch</code> podrían frenar clientes detrás de NAT o guardados grandes.	Prueba de carga.
—	El guard compara valores con <code>JSON.stringify</code> (sensible al orden de claves; falla cerrado).	Comparación estructural.
—	Login de terceros en <code>Login.jsx</code> (preexistente).	Ticket aparte.
—	Si falla el guardado del equipo o del usuario en <code>UpdateExistUserAsAdmin</code> , la organización queda creada sin uso.	Ticket aparte.

Lotes siguientes de caja blanca

- **Lote 2:** `deleteAccount`, que todavía genera su OTP con `Math.random`, y permisos por tenant.
- **Lote 3:** clases que mantienen create/update públicos: `_User`, `contracts_Contactbook`, `contracts_Document`, `contracts_Template`, `contracts_Signature`, `partners_TenantCredits`.